MIESC

Multi-layer Intelligent Evaluation for Smart Contracts

Arcadia lending-v2 — Focused Triage Report

Target: arcadia-finance/lending-v2 @ dc2ccb9 · Scope: src/ (own code; accounts-v2 dep excluded)
Scan: 85 findings (2 High / 35 Med / 48 Low) · Triage verdict: 0/2 High exploitable
Date: 2026-11-04 · Prepared by: MIESC automated static analysis (Slither) + manual triage

PUBLIC

Arcadia lending-v2 — MIESC audit triage memo

Target: `arcadia-finance/lending-v2` @ `dc2ccb9` · scope `src/` (own code; `accounts-v2` dep excluded) **What it is:** The lending layer of Arcadia Finance (margin lending on Base) — `LendingPool` (ERC4626-style debt pool), `DebtToken`, `Tranche` (senior/junior liquidity), `TrancheWrapper`, L1/L2 `Liquidator`s, and a `LendingPoolGuardian`. **Toolchain:** Foundry (solc **0.8.34** — installed via solc-select into an isolated venv and passed to forge with `--use`; the pinned forge's svm list predated 0.8.34) + Slither 0.11.3, reusing forge build-info. **Scan:** 85 owned findings — **0 Critical / 2 High / 35 Medium / 48 Low / 0 Info**. **Reports:** `Arcadia_lendingv2_Audit_EN.pdf`, `Arcadia_lendingv2_Auditoria_ES.pdf`.

> Triage layer. **Nothing here is a bounty submission.** No PoC was submitted anywhere; any disclosure is the user's own action.

Headline

Both High findings are false positives — access-gated `transferFrom(from, …)` where `from` is supplied by a trusted internal caller, **and the Arcadia team already acknowledged both** with inline `// forge-lint: disable-next-item(arbitrary-send-erc20,…)` suppressions. Fifth mature-enough target in a row with 0 exploitable Highs.

High findings — per-site verdict (2/2 FP)

1. arbitrary-send-erc20 → FP · `LendingPool.depositInLendingPool` L351

`asset.safeTransferFrom(from, address(this), assets)` with `from` a parameter. **FP:** - Modifier `onlyTranche` (`if (!isTranche[msg.sender]) revert Unauthorized()`) — only registered Tranche contracts can call. `from` is the LP who deposits *through* the Tranche; an external attacker is not a tranche and cannot reach this. - The deposit credits `realisedLiquidityOf[msg.sender]` (the tranche), consistent with who supplied the funds. - The developers explicitly suppressed this exact Slither rule inline (`// forge-lint: disable-next-item(arbitrary-send-erc20,…)`) and documented the ordering ("Address(this) is trusted -> no risk on reentrancy").

2. arbitrary-send-erc20 → FP · `LendingPool.auctionRepay` L520

`asset.safeTransferFrom(bidder, address(this), amount)` during a liquidation auction. **FP:** - Modifier `onlyLiquidator` — only the Liquidator contract can call, during an active auction, passing the real `bidder`. An external attacker cannot invoke it directly with an arbitrary `bidder`. - Same inline developer suppression and trusted-ordering comment.

Medium (35) — class characterization (spot-checked)

Class	Count	Verdict
`incorrect-equality`	14	Standard ERC4626 `totalSupply == 0 ? …` share-price branches in `Tranche` (convertToShares/Assets/deposit). Intentional.
`reentrancy-no-eth`	14	Liquidation/withdraw flows (`Tranche.withdraw`, `LendingPool._processDefault`, `settleLiquidationUnhappyFlow`). External calls are to trusted protocol contracts with documented transfer-before-state ordering. Likely FP; **team confirmation suggested** on the liquidation-settlement paths.
`unused-return`	4	Noise.
`divide-before-multiply`	3	All in `LogExpMath` (Balancer's audited fixed-point exp/ln library). Intentional precision math. FP.

Low (48)

Dominated by `timestamp` (18) and benign/event reentrancy (22), plus `events-maths` (4) and `missing-zero-check` (3). Standard hygiene; none security-relevant on spot-check.

Bottom line

- **No submittable bug** found by static scan + triage — fifth target in a row (Lombard, Doppler, Valantis STEX, YieldNest, Arcadia) with all raw Highs being false positives, now across LST / launchpad / AMM / restaking / margin-lending.

- Notably, Arcadia had **already marked both High sites with inline lint suppressions** — a nice signal that a mature team pre-triages exactly the findings a scanner surfaces.
- Honest limits: verdicts from code reading (modifier gating, ERC4626 patterns, known libraries); no PoC was needed. The liquidation-flow `reentrancy-no-eth` is the only class I'd flag for a team double-check.

Appendix — Evidence trail

- Full scan: `Arcadia_lendingv2_Audit_EN.pdf`, `Arcadia_lendingv2_Auditoria_ES.pdf`; raw: `arcadia_security_results.json`.
- Toolchain: HTTPS submodule fetch (+ `--force` for nested `accounts-v2/lib/solmate`) → `forge build --use <solc-0.8.34> --build-info --skip test/script` → `slither . --foundry-ignore-compile --json`.
- Target pin: `arcadia-finance/lending-v2` @ `dc2ccb9`.